разряд.

Навыки говорят за вас

Цифровая платформа прямого найма с подтверждённой категорией специалиста и профилем достижений ФСП

Техническое задание · Архитектура · API
Тестирование · Машинное обучение · Эксплуатация

Специальный трек Федерации спортивного программирования
Лидеры цифровой трансформации 2026
Версия 1.1 / 10 октября 2026

Содержание

Разряд - техническое задание 4

1. Назначение и границы продукта . . . 4
2. Роли и права . . . 4
3. Требования к бэкенду . . . 5
4. Требования к фронтенду . . . 8
5. Архитектура и данные . . . 9
6. API и эксплуатация . . . 10
7. Критерии приёмки и негативные сценарии . . . 10
8. Этапы реализации . . . 11
9. Комплект сдачи . . . 11

Разряд: реализация и эксплуатация 13

1. Архитектура . . . 13
2. Сущности и владение . . . 13
3. Основные правила . . . 14
4. API . . . 15
5. Защита и конкурентные операции . . . 17
6. ФСП, Keycloak и ATS: проект интеграции . . . 17
7. Запуск, обновление и восстановление . . . 18
8. Диагностика . . . 19

Разряд: методика, валидация и границы 20

1. Категория и ранжирование . . . 20
2. Обучение модели . . . 20
3. Банк заданий и test-retest . . . 21
4. Проверки реализации . . . 22
5. Что реализовано, а что требует пилота . . . 23
6. Дальнейшая приёмка с ФСП . . . 23

Материалы и порядок сдачи 25

Регламент . . . 25
Команда PixiPod . . . 25
Что осталось перед сдачей . . . 25
Сценарий защиты на 10 минут . . . 26
Проверка перед отправкой . . . 26

Как проверить «Разряд» 27

Подготовка . . . 27

1. Лендинг и регистрация . . . 27
2. Профиль и тест . . . 28
3. Подбор и приватность . . . 28
4. Вакансии, отклики и практика . . . 28
5. Негативные сценарии . . . 29
Автоматические проверки . . . 29

Готовность, модель и эксплуатация 30

Что можно утверждать . . . 30
Итоговая модель . . . 31
Публичный демонстрационный стенд . . . 31
Резервные копии и восстановление . . . 32
Зависимости и границы проверок . . . 32

Разряд - техническое задание

Версия 1.0. 10 октября 2026 года. Специальный трек ФСП, «Лидеры цифровой трансформации 2026».

1. Назначение и границы продукта

«Разряд» - платформа прямого найма ИТ-специалистов: кандидат подтверждает компетенции, работодатель выбирает категорию и приглашает конкретного человека с заранее известной зарплатой. Название продукта не означает присвоение официального спортивного разряда.

Основной путь: регистрация → профиль и согласия → опрос → выбор специализации и предполагаемого грейда → тест → подтверждённая категория → подбор работодателем → приглашение с зарплатой → решение кандидата → раскрытие контактов только этому работодателю.

Публикация вакансий и самостоятельные отклики дополняют этот путь. Агрегация означает единое пространство потребностей компаний и проверяемых профилей; парсинг чужих вакансий не является продуктовой механикой.

Основания

- Исходное «ФСП спец. трек ТЗ.pdf», 9 страниц: функциональность, безопасность, оценка, сдача.
- «Ответы на вопросы трек ФСП ЛЦТ__.xlsx», 17 ответов: грейд - навыки, а не стаж; ФСП усиливает ранжирование внутри категории; первичный тест относится к категории; синтетические данные допустимы; достаточно основных технических специализаций.
- Telegram «Специальный трек | Федерация спортивного программирования | ЛЦТ 26», темы «О важном» и General, сообщения организатора: промежуточная сдача 11.10.2026, 23:59 МСК; презентация нужна уже при промежуточной сдаче; демо или запись; финальная документация PDF; сдача капитаном через личный кабинет; эксперты должны самостоятельно видеть исходный код. Сообщения других участников не являются требованиями организаторов.
- Фирменная гамма: https://www.fsp-russia.ru/press/brandbook/ - фиолетовый #402FFF, красный #EC1D35, светлый #EDEDED, графит #1B1C21. Основа интерфейса - предоставленный Relay, Next.js и Tailwind.

Приоритеты и границы готовности

P0 - весь обязательный путь и контроль доступа. P1 - вакансии, отклики, регулярные задания, мобильный интерфейс, PDF-профиль, измеримая ML-валидация. P2 - архитектура промышленной интеграции ФСП/Keycloak, ATS, антифрод. В демонстрации интеграция ФСП использует собственный маркированный реестр: официального API на хакатоне нет. Нельзя заявлять верификацию реальной Федерацией по демонстрационным записям.

Готовность означает прохождение критериев приёмки и документированные границы. Абсолютная защита от списывания, отсутствие любых ошибок и гарантированное трудоустройство не обещаются.

2. Роли и права

Роль	Возможности	Ограничения
Гость	Лендинг, регистрация, вход, публичные вакансии	Нет банка кандидатов и персональных данных
Кандидат	Свой профиль, тесты, согласия, приглашения, отклики, задания, экспорт	Нет доступа к чужим профилям, ответам и приглашениям
Работодатель	Своя компания, потребности, вакансии, подбор, приглашения, работа с откликами	До согласия кандидата нет контактов; нет изменений чужой компании
Оператор	Аудит и модерация в промышленной модели	Отдельные полномочия, запрет незаметного изменения грейда

Проверка прав выполняется на сервере для каждого ресурса. Скрытие кнопки не считается защитой. Идентификатор работодателя берётся из сессии, а не из доверенного поля запроса.

3. Требования к бэкенду

3.1. Регистрация и сессии

Регистрация по email и паролю с выбором роли; нормализация адреса, валидация формата, уникальность без учёта регистра. Пароль минимум 10 символов, хранение стойкого хеша с индивидуальной солью. Роль после регистрации не меняется через профиль. По решению команды от 10 октября подтверждение почты в демонстрации отключено: регистрация сразу создаёт сессию. Адрес не помечается как проверенный. Опциональный режим EMAIL_VERIFICATION_REQUIRED=true сохраняет одноразовые ссылки и ограничения доступа до подтверждения.

Сессия хранится в HttpOnly-cookie, SameSite=Lax, Secure в HTTPS-окружении. Сервер хранит хеш токена, срок и владельца. Выход отзывает текущую сессию. Восстановление пароля по одноразовому токену отзывает старые сессии. Токены не выводятся в общедоступные логи. Продуктовые ошибки на русском. Ограничения на частоту входов и чувствительных запросов.

Для автономной демонстрации - локальная почтовая доставка и демонстрационные роли, включаемые отдельной настройкой. На публичном промышленном стенде демонстрационные методы отключаются. Настоящая почтовая отправка включается конфигурацией SMTP и проверяется отдельно.

3.2. Профиль кандидата

Поля: имя, город, отрасль, специализация, предполагаемый грейд, подтверждённый грейд, стек, опыт в годах, краткое описание, предпочтения по формату, зарплатные ожидания, контактный email, телефон/ссылка для связи. Грейд, балл, источник достижения и дата подтверждения недоступны для изменения обычным сохранением профиля.

Самоописанные навыки отделены от подтверждённого тестирования. Профиль может заполняться вручную; PDF-импорт - вспомогательный путь с предпросмотром, не изменяющий профиль без подтверждения. Скан без текста сообщает о невозможности извлечения; неверный MIME, слишком большой или повреждённый PDF отклоняется. Исходный PDF не публикуется работодателю, так как может содержать контакты.

PDF-экспорт стандартизирован, поддерживает кириллицу. Кандидат может скачать свой полный профиль. Версия для работодателя должна проходить тот же контроль контактов, что JSON API.

3.3. Согласия и видимость

Раздельные согласия на обработку данных и публикацию профиля; сохраняются версия, время и значение. Публикация добровольна. В банке видны только опубликованные профили с подтверждённой категорией. Отзыв публикации немедленно исключает профиль из поиска и прямого просмотра новыми работодателями.

До принятия приглашения или самостоятельного отклика контактные поля отсутствуют в ответе API; это распространяется на поиск, карточку, экспорт и ошибки. Из публичного описания удаляются очевидные email, телефоны, URL и контактные псевдонимы. Оригинальное резюме не предоставляется в подборке. Даже после раскрытия контакты видны только соответствующему работодателю. Согласие на один контакт не открывает данные всем компаниям.

Самостоятельный отклик содержит понятное предупреждение о раскрытии контактов этой компании. Неподтверждённый профиль может просматривать вакансии и откликаться, но не попадает в подтверждённый банк. Наличие ФСП не обязательно.

3.4. Опрос и справочники

Первичная отрасль - информационные технологии. В рабочем MVP обязательны две специализации: бэкенд-разработка Python и фронтенд-разработка JavaScript/React. Грейды: начальный, средний, старший (Junior, Middle, Senior как профессиональные термины в скобках). Стаж - отдельное поле и не определяет грейд. Расширение справочника без подготовленных тестов не допускается.

Опрос фиксирует специализацию, стек, формат, опыт и предполагаемый грейд. Категория присваивается только после успешного теста: specialization + verified_grade. История попыток и результаты сохраняются.

3.5. Механика тестирования

Подход: банк семейств заданий с параметризацией и фиксированным чертежом сложности. Для каждой специализации и грейда - сопоставимые семейства: алгоритмическое мышление, обработка данных, профильная технология, надёжность/безопасность. Вариант формируется криптографически случайным seed, случайными параметрами и перестановками, но с одинаковым составом компетенций и правилами подсчёта.

Числовые и структурированные ответы проверяются детерминированно. Ответы, seed и проверяющая логика не передаются в клиентские DTO. Параметры должны менять решение, а не только названия. Набор вариантов не доказывает невозможность утечки семейства: риск сохраняется, для развития нужны ротация банка, экспертная калибровка и анализ аномалий.

Попытка привязана к владельцу, версии банка, специализации и заявленному грейду. Только одна активная попытка на кандидата. TTL - 30 минут по серверным часам. Повторный старт возвращает активную попытку. Перезагрузка страницы восстанавливает её. Ответы сохраняются перед финальной отправкой. Пустые ответы - ошибки соответствующих заданий, не автоматическая успешная сдача. Повторная финализация не пересчитывает результат и не меняет даты.

Порог - 70% правильных ответов. Уверенный результат от 90% предлагает повысить уровень, но не назначает старший автоматически. Неудачная попытка не понижает действующий грейд: кандидат видит предложение попробовать ниже. Неудачный первичный тест оставляет категорию неподтверждённой. После успешного изменения грейда - интервал 90 дней; ограничения проверяются сервером. Повтор после неудачи ограничивается отдельно (сутки на тот же уровень), более низкий уровень при первичном

тесте доступен без принудительного назначения.

Сигналы ухода с вкладки могут регистрироваться как информационные, но сами по себе не ведут к обвинению или дисквалификации. Код кандидата на основном сервере не исполняется. Для будущих кодовых задач - изолированный runner без сети, с лимитами CPU, памяти, процессов, файлов и времени.

3.6. Компания и описание потребности

Профиль компании: название, описание, направление, город, корпоративный контакт. Работодатель создаёт потребность: название роли, специализация, минимальный/целевой грейд, стек, формат, текст задач, обязательная зарплата от/до в рублях. Диапазон положительный, от ≤ до; включается указание «до вычета налогов».

Потребность может быть сохранённым запросом без публичной вакансии. Система показывает категории, количество доступных специалистов и объяснимую подборку. Изменение фильтров сохраняет потребность и предыдущий запрос, не уничтожает существующие приглашения.

3.7. Поиск, ранжирование и ML

Сначала жёсткие права и фильтры: публикация, подтверждённая категория, специализация, грейд, навыки, ФСП. Затем ранжирование внутри допустимого множества. Категория не выводится из резюме с помощью ML и не повышается моделью.

Прозрачный базовый скоринг использует покрытие стека, подтверждённый тест, совпадение грейда, свежесть активности и релевантные подтверждённые достижения. Вклад ФСП ограничен, отсутствие истории не создаёт запрета. В карточке - совпавшие и недостающие навыки, балл теста, подтверждённый уровень, дата проверки и вклад каждого фактора. Сила результата не является вероятностью успешного найма.

ML-слой: локальная лёгкая обучаемая модель релевантности на обезличенных структурных признаках. Обучение на воспроизводимой синтетике с раздельными train/validation/test потребностями; seed, размер, веса, версии и метрики сохраняются. Модель сравнивается с простым базовым ранжированием, а не объявляется лучшей без измерений. Рабочий запасной путь при отсутствии артефакта - формула. LLM не требуется для корректной работы продукта.

Валидация: Precision@5, nDCG@5, доля релевантных в выдаче, согласованность test-retest, различимость сильных и слабых синтетических кандидатов. Метрики на синтетике явно отделены от внешней/экспертной валидации. Защита от круговой проверки: контрольные кейсы и разметка описываются отдельно от признаков ранжирования; синтетические зависимости и ограничения признаются в отчёте.

3.8. Приглашения и контакт

Приглашение содержит компанию, предложение, зарплату от/до, валюту RUB, способ связи работодателя; вакансия необязательна. Создание доступно только работодателю, адресат должен быть доступен этому работодателю. Дубликат активного приглашения от одной компании к тому же кандидату блокируется (409).

Состояния: отправлено → просмотрено → принято/отклонено; отправлено/просмотрено → отозвано работодателем. Окончательные состояния не переписываются. Просмотр не сбрасывает принятие. При принятии создаётся разрешение раскрытия контактов этой компании; действие записывается в аудит.

Статусы доступны обеим сторонам только по своим записям. Предложение нельзя незаметно изменить после согласия; новые условия требуют нового приглашения.

3.9. Вакансии и отклики

Компания создаёт, редактирует и архивирует собственные вакансии. Опубликованная вакансия всегда содержит зарплату. Фильтры: запрос, специализация, грейд, формат. Архивная вакансия не принимает новые отклики. Кандидат откликается один раз, может отозвать отклик. Статусы: отправлен, на рассмотрении, интервью, отказ, отозван. Работодатель изменяет только допустимые статусы своих откликов. При отклике контакты открываются только владельцу вакансии.

3.10. Регулярные задания

Работодатель публикует короткое задание по специализации. Кандидат получает соответствующую подборку; повторный ответ не создаёт второй результат. Ответ - текст решения/подхода, ограниченный по длине. Работодатель оценивает по явной рубрике 0-100 с комментарием. Только оценённое решение влияет на свежесть подтверждённого сигнала, не заменяет грейд. Автооценка свободного текста не выдаётся за объективную без проверки.

3.11. ФСП и внешние системы

Контракт реестра: внешний ID участника, ID мероприятия, дисциплина, дата, место, число участников, тип участия, источник, время синхронизации, статус проверки. Предусмотреть пустую историю, недоступный реестр, дубликат достижения, конфликт ID, отозванный результат и устаревшую синхронизацию.

В деморежиме - привязка только к специально предоставленным тестовым идентичностям, с маркировкой происхождения. Пользователь не может сам выставить признак официальной верификации. Реальный поток: OIDC Authorization Code + PKCE через Keycloak, state/nonce, проверка issuer/audience/JWKS, уникальный subject; затем серверная синхронизация по соглашению с ФСП. Email не является достаточным ключом объединения аккаунтов.

ATS-концепция: адаптеры, исходящие события через transactional outbox, идемпотентный event_id, подпись, повтор с backoff, журнал доставки и dead-letter. Синхронизируются вакансии и статусы, контакты - только при наличии основания. URL вебхука не принимается без защиты от SSRF. Для MVP достаточно документированного контракта и безопасного CSV-экспорта принадлежащих компании записей.

Антифрод-концепция: проверка ИНН/домена, лимиты приглашений, жалобы и блокировка компании, история изменений зарплаты, признак проверенной компании только после независимой процедуры. Демонстрационный статус не означает проверку госреестром.

4. Требования к фронтенду

Next.js App Router, TypeScript, Tailwind. Русский язык по умолчанию; даты в русской локали, деньги в рублях. Использовать Relay: тёмная сцена, выразительная типографика, световой поток, крупные блоки и аккуратные поверхности; фирменные цвета ФСП вместо исходного лайма. Не переносить рекламные числа, отзывы или интеграции шаблона как реальные результаты продукта.

Экраны

1. Лендинг: ценность для двух ролей, схема пути, объяснение проверок и контактов, вход в демо, регистрация.

2. Вход и регистрация; подтверждение и восстановление доступны только при настройке соответствующего режима: понятные ошибки, пароль с корректным autocomplete, согласие отдельно.

3. Кабинет кандидата: готовность профиля, текущий грейд, входящие предложения, действия следующего шага.

4. Редактор профиля и настройки публикации; импорт и экспорт PDF; ФСП и пустая история.

5. Опрос/выбор теста; прохождение с таймером, восстановлением; результат и история, дата следующей смены.

6. Приглашения: условия до принятия, раскрытие контактов с объяснением, отказ.

7. Вакансии/детали/отклики; сохранение фильтров.

8. Кабинет работодателя: потребность, банк кандидатов, категории, объяснения и просмотр профиля.

9. Создание приглашения, статусы и контакты после согласия.

10. Компания, собственные вакансии, отклики, регулярные задания и проверка решений.

11. Страница методики: понятное объяснение баллов, границ ML и демоданных.

Общие состояния

Для каждого списка: загрузка, ошибка с повтором, пустой результат, заполненный список. Для каждой формы: валидация, ожидание, успешный результат, серверная ошибка; защита от повторной отправки. Истечение сессии ведёт ко входу. Запрет доступа отличается от пустого списка. Фильтры не очищаются при ошибке сети.

Доступность: семантические кнопки/ссылки, label, aria-live для результатов, видимый фокус, клавиатура, контраст, отсутствие зависимости от цвета. Мобильные экраны от 360 px; основные действия не обрезаются. prefers-reduced-motion отключает декоративные движения; WebGL не блокирует использование продукта. Кабинеты обходятся без тяжёлой 3D-сцены.

5. Архитектура и данные

Модульный Python/FastAPI backend, SQLAlchemy, PostgreSQL в Docker, SQLite для простого локального запуска; модель данных и ограничения совместимы с обеими СУБД. Next.js обращается к API по единому origin через reverse proxy. Изоляция слоёв: маршруты и схемы → доменные правила → хранилище; ML - чистый сервис без доступа к контактам. Контейнеры web/api/db/mail. Версии фиксируются lock-файлами/requirements.

Сущности: User, Session, VerificationToken, CandidateProfile, Company, ConsentEvent, AssessmentAttempt, AssessmentAnswer, Achievement, Need, Vacancy, Invitation, ContactGrant, Application, Challenge, ChallengeSubmission, AuditEvent. Все времена хранятся в UTC, отображаются в локали пользователя. Денежные суммы - целые рубли. Публичные идентификаторы непрозрачны. Важные изменения выполняются транзакционно; уникальные ограничения дублируют программные проверки.

Индексы: уникальный email, токены, специализация/грейд/публикация, владелец и статус приглашения, уникальный кандидат+вакансия, внешний ID достижения. Чтение не должно случайно создавать данные. Начальные демоданные создаются отдельной идемпотентной командой, не при каждом старте сервера.

6. API и эксплуатация

Префикс /api/v1. Группы: auth, me/profile, assessments, companies, needs, candidates, invitations, vacancies, applications, challenges, integrations/fsp, metrics. OpenAPI - машинный контракт; документация описывает запросы, ответы, ошибки и необходимость авторизации. Ожидаемые коды: 200/201/204, 400/422, 401, 403, 404, 409, 413, 429, 503.

Health endpoint, аудит критических действий, сообщения об ошибках без stack trace и паролей. Лимит JSON и PDF, таймауты внешних сервисов. Origin/CSRF-контроль для мутаций, запрет wildcard CORS с cookie. Продакшен: HTTPS, секреты окружения, отдельный пользователь БД, резервные копии и проверка восстановления. Не выдавать прототип за сертифицированную систему обработки персональных данных.

Ориентир: десятки одновременных пользователей, поиск p95 менее 1 секунды на демонаборе; фактические результаты и машина фиксируются в отчёте. Пагинация/лимиты защищают от неограниченных ответов. Контейнеры работают без обязательного GPU и платных API.

7. Критерии приёмки и негативные сценарии

ID	Проверка	Ожидаемый результат
A01	Регистрация и вход	В демонстрации вход сразу после регистрации; адрес не помечается проверенным. В опциональном режиме подтверждения токен одноразовый
A02	Слабый первичный тест	Нет подтверждённой категории; предложен нижний уровень
A03	Сильный тест	Категория присвоена сервером, история и дата записаны
A04	Повторная сдача результата	Не меняет результат/дату, не даёт дополнительный грейд
A05	Чужая попытка/профиль/приглашение	403/404, без данных владельца
A06	Таймаут/перезагрузка теста	Серверное ограничение времени, восстановление активного состояния
A07	Смена грейда до 90 дней	Сервер отклоняет, дата доступности объяснена
A08	Подбор по потребности	Только допустимые категории; причины и стек видны
A09	Профиль без ФСП	Полный путь работает, явное пустое состояние
A10	Приглашение без зарплаты/перевёрнутый диапазон	422, запись не создаётся
A11	До принятия, после принятия, другая компания	Контакты скрыты → раскрыты владельцу → скрыты другой компании
A12	Дубликат/неправильный переход статуса	409, история сохраняется

ID	Проверка	Ожидаемый результат
A13	Отзыв публикации	Профиль исчезает из нового поиска и прямого чтения
A14	Самостоятельный отклик	Контакты доступны только компании вакансии; дубль запрещён
A15	Архивная/чужая вакансия	Нет новых откликов/нет редактирования чужой
A16	Повреждённый/огромный PDF	Русская ошибка, сервер не падает; контакты не публикуются
A17	Пустая выдача/сеть/истёкшая сессия	Корректный экран и восстановление
A18	Регулярное задание	Только владелец проверяет; грейд не меняется
A19	Модель отсутствует	Подбор работает по объяснимой формуле
A20	Мобильный/клавиатура/reduced motion	Полный основной путь доступен
A21	Сборка и свежая БД	Воспроизводимый запуск по README

Тесты: доменные unit, API integration с двумя работодателями и двумя кандидатами, браузерные сквозные сценарии, сборка/линтер/проверка типов, контроль Git на секреты и служебные файлы. Метрики тестирования и ML воспроизводятся отдельными командами. Утечка контактов и подмена подтверждённого грейда - блокирующие дефекты.

8. Этапы реализации

1. Анализ источников, это ТЗ, матрица соответствия, каркас репозитория.

2. Модель данных, авторизация/подтверждение почты, профиль/согласия, тестирование и контроль доступа; интеграционные тесты.

3. Потребности, ранжирование, приглашения/контакты, вакансии/отклики, регулярные задания; тесты инвариантов.

4. Обучение и оценка локальной модели, тест-retest, отчёт и ограничения.

5. Русский Relay-лендинг и кабинеты; реальное соединение с API, мобильная и клавиатурная проверка.

6. Docker, инструкции, OpenAPI, PDF-документация, презентация на предоставленном шаблоне, демонстрационные материалы; финальный прогон.

После каждого этапа - проверка и отдельный тематический коммит в формате feat(scope)/fix(scope)/docs(scope)/test(scope): краткое русское описание. Автор берётся из пользовательской Git-конфигурации. Секреты, исходные архивы, локальные данные и служебные файлы разработки не включаются.

9. Комплект сдачи

- Открытый исходный код с историей и инструкцией: https://github.com/ArtycoBW/-
- Презентация PPTX/PDF, регламент выступления - 10 минут по ответам организаторов.
- Работающий стенд или запись сквозного сценария плюс локальный запуск.
- PDF: архитектура, тестирование/устойчивость, подбор/категории, валидация и фактические результаты, ФСП/Keycloak, API, версии компонентов, сборка и эксплуатация.
- README остаётся удобной точкой входа; PDF строится из актуального описания реализации.
- Демодоступы и синтетическое происхождение данных маркируются. Не заявлять промышленную готовность интеграций, экспертную калибровку или результаты нагрузочного теста без измерений.

Разряд: реализация и эксплуатация

Версия 1.0, 10 октября 2026 года. Этот документ описывает работающий прототип, а не обещания из дорожной карты. Исходные требования и критерии приёмки находятся в техническом задании.

1. Архитектура

Браузер обращается к Next.js по одному адресу. Запросы /api/v1/* проксируются в FastAPI. Cookie сессии остаётся HttpOnly, токен не хранится в localStorage. FastAPI проверяет роль и владельца объекта, выполняет доменную операцию в транзакции и обращается к SQLAlchemy. В контейнерах используется PostgreSQL 17, в локальном сценарии - SQLite с WAL и внешними ключами.

Поток данных: браузер → Next.js → FastAPI → SQLAlchemy → БД. Ответ подбора проходит отдельный сериализатор контактов. Модуль ранжирования получает только структурные признаки. SMTP поддерживает опциональные одноразовые ссылки; в текущей демонстрации подтверждение и восстановление по почте отключены. PDF разбирается на сервере и возвращает черновик для ручного подтверждения. Произвольный код кандидата не исполняется.

Компонент	Назначение	Основные файлы
Frontend	Лендинг, две роли, формы и состояния	frontend/src/views/product, frontend/src/views/home
API	HTTP, авторизация, доменные переходы	backend/main.py, security.py, schemas.py
Хранилище	Сущности, связи, транзакции	backend/models.py, db.py
Тестирование	Параметризованные варианты и проверка	backend/assessment.py
Подбор	Признаки, формула, безопасная загрузка модели	backend/matching.py
Обучение	Синтетика, независимые разбиения и метрики	ml/train.py, model.json, metrics.json
Демоданные	Идемпотентное наполнение стенда	backend/seed.py

Frontend: Next.js 16.4, React 19, TypeScript, Tailwind 4. Предоставленный Relay сохранён как основа лендинга: композиция, spring-анимации, Lenis, декоративная Three.js-сцена. Кабинеты имеют отдельную лёгкую компоновку. Цвета и тексты адаптированы под «Разряд», кириллица поддерживается шрифтами Inter, Lora и JetBrains Mono. В режиме reduced motion декоративное движение ограничивается.

Backend: Python 3.12, FastAPI, Pydantic, SQLAlchemy, psycopg, Argon2, pypdf, ReportLab. ML: NumPy, SciPy, scikit-learn. Точные версии зафиксированы в requirements.txt и package-lock.json. Для работы продукта не нужны GPU, внешняя LLM или платный API.

2. Сущности и владение

Сущность	Ключевые данные	Правило
User	email, хеш пароля, роль, verified	Уникальный нормализованный email

Сущность	Ключевые данные	Правило
Session / Token	хеш токена, владелец, срок	Сессия 7 дней; ссылка 1 час, одноразовая
Candidate	специализация, desired_grade, grade, score, skills, consent	Подтверждённые поля изменяет только тест
Company	название, описание, отрасль, контакт	Доступ на изменение только владельцу
Attempt	seed, версия банка, вопросы, ответы, сроки	Вариант и ответы принадлежат кандидату
Achievement	внешний ID, событие, дисциплина, место, источник	Демореестр явно отличается от официального
Need	категория, стек, задачи, формат, зарплата	Сохранённая потребность компании
Vacancy	потребность и признак архива	Публичное предложение компании
Invitation	две стороны, зарплата, сообщение, статус	Закрытый диалог с конкретным кандидатом
ContactGrant	компания, кандидат, причина	Уникальная пара, адресное раскрытие
Application	кандидат, вакансия, письмо, статус	Один отклик на вакансию
Challenge / Submission	задача, рубрика, ответ, оценка	Оценивает только создавшая задачу компания
Audit	действие, субъект, объект, время, детали	Согласия и важные доменные события

Связи: User 1:1 Candidate либо Company; Candidate 1:N Attempt и Achievement; Company 1:N Need, Vacancy, Invitation, Challenge; Candidate N:M Company через ContactGrant; Candidate N:M Vacancy через Application; Candidate N:M Challenge через Submission.

ID - случайная строка UUID без дефисов. Время - UTC Unix seconds. Зарплата - целые рубли в месяц до вычета налогов. JSON-поля используются для навыков, вопросов и ответов. Ответы и seed исключены из публичного DTO теста. Согласия записываются событиями Audit с версией 1.0.

3. Основные правила

Проверка навыков

Кандидат выбирает одну из двух специализаций и один из трёх уровней. Стаж не назначает грейд. До теста нужны имя, навыки и согласие на обработку. Один активный тест длится 30 минут. Повторный старт возвращает текущую попытку; ответы можно сохранить и восстановить после перезагрузки.

Восемь вопросов имеют одинаковый чертёж для заданной категории. Успех - не менее 70 баллов: при восьми равновесных вопросах это минимум шесть верных ответов, то есть 75 фактических баллов. Успех меняет категорию, неудача сохраняет предыдущую. Повтор того же уровня после неудачи доступен через сутки; нижний уровень можно попробовать сразу, если нет блокировки после успешного подтверждения. После успеха смена категории ограничена 90 днями. Повторная отправка завершённой попытки

возвращает прежний результат.

Обратный найм

Компания создаёт потребность, выбирает категорию и получает ранжированный банк. Потребность не обязана становиться вакансией. Нельзя переопределить категорию потребности несовместимым query-фильтром. Без потребности доступен обзор опубликованных подтверждённых специалистов; персональная релевантность надёжнее интерпретируется после выбора потребности.

Приглашение содержит роль, текст, контакт компании и положительный диапазон зарплаты. До отправки проверяется публикация профиля. Два одновременных запроса не создают два активных приглашения одной пары. Состояния: sent → viewed → accepted / declined; отправитель может перевести sent / viewed в withdrawn. Из терминального состояния новый переход запрещён. Повтор того же допустимого решения идемпотентен.

Принятие создаёт ContactGrant для конкретной компании. Контакт не появляется у других работодателей. Самостоятельный отклик также создаёт адресный доступ после отдельного согласия. Отзыв публикации убирает человека из нового поиска; ранее выданный доступ сохраняется. Возврат уже переданных контактных данных технически невозможен. В разделе профиля специалист видит выданные доступы и может отозвать ContactGrant для конкретной компании. Повтор принятия старого приглашения не восстанавливает отозванный доступ. Удаление аккаунта и управление сроками хранения остаются задачами пилота.

Вакансии поддерживают создание, редактирование и архив. Отклик на архивную вакансию запрещён. Статусы отклика: sent, reviewing, interview, rejected, withdrawn. Повторный отклик не создаётся. Задачи компании доступны кандидатам соответствующей специализации; проверка по явной рубрике обновляет сигнал активности при результате от 70, но не меняет грейд.

PDF

Импорт принимает PDF до 5 МБ и до 20 страниц, проверяет сигнатуру и текстовый слой. Зашифрованный или повреждённый файл отклоняется. Исходный файл не сохраняется и не передаётся работодателю. Из текста извлекаются начальная строка, описание, email и совпадения с небольшим словарём навыков. Это эвристический черновик, возможны ошибки распознавания. OCR и произвольные макеты не поддерживаются. Экспорт собственного профиля формирует PDF с кириллицей.

4. API

Swagger: /api/v1/docs; JSON: /api/v1/openapi.json. Экспорт контракта лежит в docs/openapi.json. Схемы входных данных строгие: неизвестные поля отклоняются, поэтому нельзя подставить grade, score или чужой company_id через сохранение профиля. Ответы с условным раскрытием контактов дополнительно описаны ниже; OpenAPI не заменяет серверную проверку прав.

Группа	Методы и пути	Доступ
Система	GET health, catalog, metrics	Публичный
Авторизация	POST auth/register, verify, login, logout, recover, resend, reset	По сценарию; ссылки одноразовые
Текущий пользователь	GET auth/me	Сессия

Группа	Методы и пути	Доступ
Демо	POST auth/demo/{role}	Только DEMO_MODE
Профиль	GET/PUT profile; GET profile/pdf; POST profile/import-pdf	Кандидат
Компания	GET/PUT company	Работодатель
Тесты	GET/POST assessments; PUT {id}/answers; POST {id}/submit	Кандидат-владелец
Подбор	GET/POST needs; GET candidates; GET candidates/{id}	Работодатель
Приглашения	GET/POST invitations; PATCH invitations/{id}	Участники диалога
Вакансии	GET/POST vacancies; PUT/PATCH vacancies/{id}; GET company/vacancies	Чтение публичное; изменение владельцем
Отклики	POST vacancies/{id}/applications; GET applications; PATCH applications/{id}	Кандидат и владелец вакансии
Практика	GET/POST challenges; POST challenges/{id}/submissions; POST submissions/{id}/review	Соответствующая роль и владелец
ФСП	POST/DELETE integrations/fsp	Кандидат; привязка только в демо

Все пути в таблице имеют префикс /api/v1. Авторизация - cookie razryad_session. Поиск принимает need_id, specialization, grade, skill, fsp, offset и limit; limit не больше 100. Ответ: items, total, offset, limit. Списки собственных сущностей небольшого прототипа пока возвращаются целиком.

Candidate DTO содержит профиль, category, achievements, grade_change_available_at, contacts_unlocked. Поля email/contact отсутствуют до согласия; consent и fsp_id доступны только владельцу. Match содержит score, mode, baseline_score, learned_score, blend, matched_skills, missing_skills, factors, explanation и notice. contribution показывает вклад фактора в формулу; итог гибрида описывается отдельно.

Attempt DTO содержит вопросы без правильных ответов и внутреннего seed, сохранённый черновик, сроки, результат. После завершения outcomes указывает корректность по каждому вопросу. Invitation DTO содержит условия и статус, а candidate_email/candidate_contact - только для получившей доступ компании.

Код	Значение
400	Недействительная ссылка или некорректный запрос
401	Нет действующей сессии
403	Не та роль, недопустимый Origin; неподтверждённая почта только при включённом EMAIL_VERIFICATION_REQUIRED
404	Ресурс отсутствует или скрыт правилами владения
409	Дубликат, закрытый переход, период ожидания

Код	Значение
413	Превышен размер запроса или PDF
422	Ошибка полей, зарплаты, категории или формата
429	Ограничение частоты авторизации
503	Почта или официальная интеграция не настроена

Ошибки имеют поле detail на русском; при валидации также fields с путём поля и машинным кодом. Клиент показывает ошибку, сохраняет заполнение и позволяет повторить действие. При 401 кабинет направляет пользователя на вход.

5. Защита и конкурентные операции

Пароли хешируются Argon2, токены - SHA-256 от криптографически случайной строки. Cookie HttpOnly, SameSite=Lax, Secure включается для HTTPS. Origin проверяется для мутаций; запросы без Origin допускаются для серверных клиентов. CORS с произвольным источником не включён. Ответы API получают no-store, nosniff, DENY и same-origin referrer policy.

Уникальные ограничения защищают email, внешний ID ФСП, пару доступа, отклики и решения задач. В PostgreSQL критические переходы тестов/приглашений используют блокировку строки. В SQLite мутации начинают BEGIN IMMEDIATE до чтения, поскольку SELECT FOR UPDATE там не действует. Конкурентные тесты проверяют повторное приглашение и старт попытки.

Публичный сериализатор исключает контактные поля и маскирует очевидные email, URL, телефоны и @псевдонимы в свободном тексте. Это не гарантирует обнаружение намеренно замаскированного контакта. PDF-резюме не публикуется. В Audit не записываются пароли, токены и тексты резюме.

Ограничитель авторизации хранится в памяти одного процесса: 30 запросов в минуту на IP и путь. Он не заменяет распределённый лимитер; за reverse proxy клиенты могут делить IP. До внешнего пилота нужен согласованный trusted proxy и Redis/edge-limiter. Лимит Content-Length не является потоковой защитой от всех chunked-запросов: на внешнем прокси обязателен реальный лимит тела. Разбор PDF должен быть вынесен в ограниченный по времени и памяти worker перед приёмом недоверенного массового трафика.

6. ФСП, Keycloak и ATS: проект интеграции

Сейчас доступен только маркированный демореестр. ID DEMO-FSP-2026 уникален; повторная привязка к другому профилю отклоняется. Достижения содержат source=demo_registry. Отключение удаляет локальные демонстрационные достижения. Никакие данные не отправляются в ФСП.

Промышленный контракт: OIDC Authorization Code + PKCE через Keycloak; обязательные state и nonce; проверка issuer, audience, подписи по JWKS и срока. Идентичность связывается по паре issuer/sub, а не по изменяемому email. Account linking требует действующей локальной сессии и повторного подтверждения, чтобы не захватить чужой профиль.

После согласия отдельный адаптер получает результаты соревнований из согласованного API. Ключ импорта - provider + external_event_id + participant_sub. Хранятся source, fetched_at, version и статус отзыва; обновление идемпотентно. Устаревшая запись не становится «актуально подтверждённой» при сетевой ошибке. Webhook проверяется подписью и защитой от повторов. Секреты остаются на сервере.

До получения спецификации API, credentials и правовой модели такой адаптер нельзя считать подключённым.

ATS: предложен outbox событий vacancy.published, application.created, invitation.accepted и application.status_changed. Доставка с event_id, tenant_id, версией схемы и idempotency key; exponential backoff с jitter, dead-letter очередь, ручное повторение. Подпись HMAC, отдельные ключи компании, контроль статусов и конфликтов. Передача контактов проверяет ContactGrant при формировании каждого события. Это документированный контракт развития; отправки в реальную ATS в версии 1.0 нет.

7. Запуск, обновление и восстановление

Полные команды для Windows и Docker приведены в README. Локальный старт использует SQLite, Docker - PostgreSQL. В Compose доступ наружу ограничен 127.0.0.1; порт БД не публикуется. Mailpit показывает тестовую доставку писем. API и web выполняются непривилегированными пользователями контейнеров.

Переменная	Назначение
DATABASE_URL	SQLAlchemy URL SQLite или PostgreSQL
DEMO_MODE	Демоаккаунты, возврат ссылки письма, демореестр ФСП
PUBLIC_ORIGIN	Разрешённый origin и адрес ссылок в письмах
COOKIE_SECURE	Secure cookie при HTTPS
SMTP_HOST / PORT / FROM	Сервер и отправитель почты
SMTP_STARTTLS / USERNAME / PASSWORD	Защищённое SMTP-соединение и учётные данные
MODEL_PATH	Путь к проверяемому JSON модели
MAIL_DIR	Локальные письма только для демо без SMTP
API_INTERNAL_URL	Адрес API для rewrites во время сборки Next.js

В локальном Python значения берутся из окружения: .env автоматически не читается. Compose читает .env для подстановок. Текущая Compose-конфигурация намеренно подключает API к Mailpit; для внешнего SMTP нужно изменить environment сервиса api. Смена API_INTERNAL_URL требует пересборки web.

Начальная схема создаётся create_all на пустой БД. Это не система миграций существующих таблиц. До первого изменения схемы на пилоте требуется ввести Alembic, зафиксировать baseline текущей модели, проверить upgrade/rollback на копии и сделать резервную копию. Не использовать удаление volume как способ обновления рабочих данных.

Резервная копия PostgreSQL: выполнить pg_dump -U razryad -d razryad -Fc -f /tmp/razryad.dump внутри db-контейнера, затем docker compose cp db:/tmp/razryad.dump в закрытое хранилище. Восстановление проверять в отдельной БД командой pg_restore, после чего выполнить вход, чтение профиля и историю приглашений. В Windows нельзя пропускать бинарный dump через старый текстовый PowerShell redirect. SQLite копировать штатным backup API при остановленных мутациях. Копии содержат персональные данные и требуют ограничения доступа.

Перед внешним пилотом: HTTPS, DEMO_MODE=false, COOKIE_SECURE=true, отдельные секреты, реальный SMTP, политика хранения/удаления и отзыва согласий, проверка компаний, централизованный аудит и мониторинг, резервное копирование с испытанием восстановления, миграции. Это эксплуатационные условия, а не выполненная сертификация.

8. Диагностика

- Порт 3000 занят: уже работает dev-сервер или web-контейнер. Выберите один способ запуска.
- 503 при включённой почтовой верификации: настроить SMTP. На текущем стенде EMAIL_VERIFICATION_REQUIRED=false и почта для регистрации не нужна.
- Пустой демобанк: выполнить backend.seed в той же БД, которую использует API.
- Ошибка Origin: PUBLIC_ORIGIN должен точно совпадать со схемой, хостом и портом браузера.
- Модель не найдена: подбор остаётся доступным с mode=rules-v1; выполнить обучение или вернуть model.json.
- При включении почтового режима Docker отправляет письма только в локальный Mailpit на localhost:8025. На текущем стенде отправка писем для входа не нужна.
- Нужны результаты проверки: команды и критерии перечислены в следующем документе; приватные локальные логи в Git не входят.

Разряд: методика, валидация и границы

Версия 1.0, 10 октября 2026 года. Все стартовые профили и обучающие данные синтетические. Ни одна приведённая метрика не описывает реальный найм.

1. Категория и ранжирование

Категория - специализация и подтверждённый грейд. Она назначается серверным тестом, не моделью и не стажем. Достижения ФСП усиливают порядок внутри категории. Кандидат без ФСП проходит весь путь. При выборе потребности специализация и грейд - жёсткие фильтры; ранжирование начинается после проверки согласия, публикации и категории.

Признак	Определение	Вес формулы
skills	Доля навыков потребности, найденных в профиле	0,40
test	Балл подтверждённого теста / 100	0,25
grade	Совпадение уровня; в выбранной категории равно 1	0,15
freshness	max(0, 1 − дней с активности / 180)	0,07
fsp	min(число достижений, 3) / 3	0,08
format	Совпадение формата работы	0,05

Названия навыков нормализуются: регистр, пробелы и небольшой словарь эквивалентов (js/javascript, postgres/postgresql, py/python и другие). Возраст, пол, гражданство, ФИО, контакты и текст резюме не входят в признаки. Самоописанный стек остаётся самоописанным; совпадение ключевых слов не объявляется доказанной компетенцией.

Формула: baseline = сумма(weight × feature). Модель: learned = sigmoid(intercept + сумма(coef × feature)). Рабочий результат: 100 × (0,7 × baseline + 0,3 × learned). При отсутствии или некорректном JSON используется 100 × baseline. Коэффициенты и порядок признаков проверяются; pickle не загружается. При равных баллах порядок детерминирован по ID.

В интерфейсе показаны совпавшие и недостающие навыки, тест, достижения, вклад каждого признака в формулу и способ смешивания с моделью. Балл - ориентир релевантности, не вероятность трудоустройства. Вес ФСП в формуле ограничен 8 баллами; в обученной части влияние определяется коэффициентом модели. Это не причинная оценка спортивных достижений.

2. Обучение модели

Воспроизведение: .venv/Scripts/python.exe -m ml.train. Seed 20261010. LogisticRegression(C=1.0), шесть признаков, max_iter=1000, CPU. Гиперпараметры фиксированы заранее; тестовая часть не используется для выбора C или смеси 70/30. Результат экспортируется в ml/model.json и ml/metrics.json. SHA-256 модели записан в отчёте, чтобы проверить соответствие артефакта.

Генератор создаёт независимые потребности и кандидатов на каждом разбиении. На потребность приходится 32 кандидата. Train: 160 подборок и 5120 пар; validation: 40 и 1280; test: 60 и 1920. Идентичные профили и потребности не переносятся между разбиениями. Метки создаются отдельной нелинейной функцией полезности с шумом; бинарная метка сэмплируется, порядковая релевантность принимает значения 0-3. Это содержательно богаче проверки на самой базовой формуле, но всё равно зависит от искусственно заданных предпосылок генератора.

Подход	nDCG@5, test	Precision@5, test
Формула	0,9774	0,9633
Только модель	0,9914	0,9833
Гибрид 70/30	0,9904	0,9867
Без сигнала ФСП	0,9891	0,9833

Validation ROC AUC - 0,8156. Test ROC AUC - 0,8248, Brier - 0,1698. nDCG учитывает положение релевантного кандидата в первых пяти; Precision@5 - долю кандидатов с целевой релевантностью в первых пяти. AUC оценивает бинарную метку генератора, Brier - ошибку вероятностного выхода модели. Гибридный балл не выдаётся за откалиброванную вероятность.

Гибрид немного уступает чистой модели по nDCG, но сохраняет большую долю прозрачной формулы и получает более высокую Precision@5 в этом прогоне. Разница мала и не является доказательством статистической значимости. Высокие значения ожидаемы при согласованном синтетическом генераторе; вывод ограничен этим сценарием. Для реальных выводов нужны независимая разметка работодателей, временной holdout, доверительные интервалы и сравнение с действующим процессом найма.

3. Банк заданий и test-retest

Банк версии 1.0 содержит две специализации и три уровня. В каждом варианте восемь заданий: два повторения четырёх семейств с различными параметрами. Семейства: алгоритмы, Python/JavaScript, SQL/React/CSS или надёжность, лимиты/TTL/backoff. Seed определяет параметры и перестановку. Ответы числовые, проверка детерминированная; NaN и бесконечности не считаются верными.

Фиксированный чертёж сохраняет состав компетенций, а параметры меняют ответ. Правильные ответы, seed и объяснения не передаются браузеру. Возможность запомнить семейство остаётся: параметризация уменьшает ценность утечки одного варианта, но не решает задачу профессионального прокторинга. Уровни пока обозначают продуктовую гипотезу сложности; арифметические микро-задачи сами по себе не подтверждают индустриальный Senior.

Симуляция IRT создаёт 1200 виртуальных участников с латентной способностью и вероятностными ответами в двух прохождениях. Сравниваются баллы и решение «прошёл/не прошёл». Отдельно генерируются 600 реальных вариантов банка для контроля уникальности и состава семейств.

Проверка	Результат
Уникальные варианты	600 из 600
Одинаковый чертёж	600 из 600

Проверка	Результат
Spearman test-retest	0,8541
Согласие по прохождению	86,08%
Cohen kappa	0,7171
Среднее абсолютное различие баллов	12,84 пункта
Item-total корреляции	0,57-0,64

Эти показатели относятся к симулированным ответам, не к эксперименту с людьми. Короткий тест имеет заметную ошибку около порога. Для пилота нужны экспертная разметка сложности, более широкий банк, задания на проектирование/дебаггинг, реальный test-retest с интервалом и контрольный профессиональный критерий. Рекомендуется оценивать различимость по каждой специализации/уровню отдельно и не трактовать единственную неудачу как доказательство низкой квалификации.

4. Проверки реализации

Серверный набор: 31 pytest-проверка, включая параметризованные случаи шести категорий. Проверены одноразовые ссылки, подтверждение почты, роли и владельцы, скрытие контактов от другой компании в карточке и пакетной выдаче, защита подтверждённых полей, тест/сохранение/повтор/таймаут, ограничения по времени, зарплата, архив и отклики, PDF, модель без артефакта, конкурентный старт теста и конкурентное приглашение, практика и рубрика работодателя. Итоговый прогон обновления: 31 успешная, 69,36 секунды. Дополнительно проверены регистрация без письма, недоступность почтовых маршрутов в публичном режиме, отсутствие утечки одноразовых ссылок, адресный отзыв контактов, целостность артефакта модели и безопасный fallback. Предупреждение Starlette о будущем переходе с httpx на httpx2 не влияет на результат.

Браузерный набор: три Playwright-проверки в Chrome. Полный новый аккаунт проходит регистрацию без письма, профиль, сохранение теста, перезагрузку, успешную сдачу, поиск работодателем, приглашение и адресное раскрытие контакта. Отдельно проверены мобильный кабинет, отсутствие горизонтального переполнения, фокус в модальном окне, Escape и переход с мобильного лендинга.

Правильные ответы для E2E читаются доверенной тестовой фикстурой из локальной SQLite, а не через пользовательский API. Такой тест проверяет интеграцию и права, а не интеллектуальные способности участника. Скрипт создаёт только синтетические e2e-аккаунты. Серверные тесты используют отдельную тестовую БД.

Критерии ТЗ	Подтверждение
A01-A07	API-тесты регистрации/тестирования/прав; полный E2E
A08-A09	Категория потребности, профиль без ФСП, объяснение выдачи
A10-A13	Диапазон зарплаты, дубликаты, два работодателя, отзыв публикации
A14-A16	Отклики, архив/владение, повреждённый и корректный PDF
A17	UI-состояния и обработка 401; полная матрица сетевых отказов не автоматизирована

Критерии ТЗ	Подтверждение
A18-A19	Рубрика/владелец/неизменность грейда; fallback формулы
A20	Chrome desktop/mobile, клавиатура; полноценный аудит WCAG не проводился
A21	Lock-файлы, сборка Next.js, Docker, свежая PostgreSQL и seed

Команды: pytest, npm run lint, npm run typecheck, npm run build, npm run test:e2e. Исходные три браузерных сценария ранее проверялись на SQLite. Текущий набор расширен до семи сценариев на production-сборке Docker с PostgreSQL: сквозной найм, модальное окно, мобильный лендинг, регрессии вёрстки, авторизация и все разделы двух мобильных кабинетов. Все семь прошли за 25,8 секунды. Письмо больше не входит в текущий основной путь. Историческая проверка SMTP в Mailpit относится к опциональному режиму. Линтер, TypeScript и сборки Next.js/API прошли. Резервная копия PostgreSQL восстановлена в отдельную временную базу; проверено наличие пользователей, специалистов, компаний и вакансий.

Нагрузочный smoke-тест: 100 запросов, 10 одновременно, GET /api/v1/candidates?limit=12 через production Next.js, один прогрев. Машина Windows, Ryzen 5 2600X, около 32 ГиБ памяти; Docker Desktop, PostgreSQL 17. После пакетной загрузки связей: 38 опубликованных профилей, 100 ответов HTTP 200, p50 354,23 мс, p95 684,49 мс, максимум 983,19 мс, 25,26 запроса/с. Исходная версия с N+1 на 37 профилях имела p95 2512,14 мс. Прогоны последовательные, объём отличается на один синтетический профиль; это ориентир улучшения, не контролируемый эксперимент. Файлы docs/performance.json и performance-before.json сохраняют условия и результаты. Результат на небольшом демонаборе не экстраполируется на десятки тысяч профилей.

Производственные npm-зависимости: npm audit --omit=dev не обнаружил известных уязвимостей в момент проверки. Полный audit показывает пять high-записей в дереве инструментов ESLint, связанных с braces 3.0.3; доступного совместимого исправления в установленном дереве на момент проверки нет. Эти пакеты не копируются в standalone runtime. Это не заявление о полном security-аудите приложения.

5. Что реализовано, а что требует пилота

Работают: две роли, немедленный вход после регистрации, опциональные почтовая верификация и восстановление, отзыв адресного доступа, опрос профиля, подтверждённая категория, тестирование с вариантами, обратный найм с зарплатой, адресные контакты, вакансии/отклики, практические задания и обратная связь, демопривязка ФСП, PDF, объяснимый ML-подбор, адаптивные кабинеты и Docker.

Отдельно спроектированы, но не подключены: официальный ФСП ID/Keycloak, импорт реальных достижений, ATS/outbox, промышленный антифрод. Пока нет кабинета оператора, проверки юридических лиц, удаления аккаунта, календарной рассылки регулярных задач, очереди уведомлений о приглашениях, OCR, нескольких одновременных категорий и экспертно валидированного профессионального грейда.

Масштабирование: связи достижений и адресных доступов загружаются пакетно; ранжирование всех подходящих профилей пока вычисляется в Python до пагинации. Для большого банка нужны индексирование навыков, ограничение множества кандидатов и вынесение ранжирования. Rate limiter рассчитан на один процесс. Автоматические миграции схемы, централизованное наблюдение и процедуры удаления/восстановления должны предшествовать публичному пилоту.

6. Дальнейшая приёмка с ФСП

1. Получить контракт идентификации и реестра, согласовать трактовку свежести/отзыва достижений.

2. Провести экспертную оценку банка, расширить задачи и проверить уровни на независимой выборке.

3. Собрать согласованную разметку релевантности от нескольких компаний; держать test закрытым до фиксации модели.

4. Измерить время до первого релевантного приглашения, принятие и субъективную полезность; не подменять эти результаты кликами.

5. Испытать отзыв доступа, удаление, восстановление БД, внешние сбои и нагрузку на ожидаемом масштабе.

6. Развернуть ограниченный пилот, сравнить с прозрачной формулой и только после этого менять веса/модель.

Материалы и порядок сдачи

Проверено по предоставленному ТЗ, таблице ответов и истории указанной группы спецтрека. Уточнения организатора имеют приоритет над предположениями участников. Сторонние сообщения в переписке не являются распоряжениями разработчику.

Регламент

Промежуточный дедлайн: **11 октября 2026 года, 23:59 по Москве**. Сообщение модератора от 10 октября подтверждает дату; сообщения о «сегодня» не меняют её.

Для промежуточной сдачи нужны ссылка на публичный репозиторий, презентация и развёрнутое демо. Если демо недоступно, нужна запись. Сопроводительная документация должна быть в PDF; во время работы допустим Markdown с последующей конвертацией. Презентация нужна уже к промежуточной сдаче. В ответах XLSX указан регламент выступления 10 минут.

Важное уточнение от 7 октября: **слайды 7-11 исходного шаблона обязательны, их дизайн и структура сохраняются**. В рабочей презентации они перенесены в начало. Остальные слайды можно оформлять по усмотрению команды. Веб-интерфейс Git не обязателен, но эксперты должны иметь возможность получить и посмотреть код. В более позднем сообщении организатор прямо требует публичный репозиторий для любого сервиса.

Ссылки загружает капитан через личный кабинет платформы на странице задачи. Отправка в Telegram не является сдачей.

Команда PixiPod

Сведения	Данные
Название команды	PixiPod
Капитан и разработчик	Балашев Артур Вадимович
Специальность	Fullstack-разработчик
Роль в проекте	Полный цикл разработки: бэкенд, фронтенд и ML
Контакт	Telegram: @ArtycoB
Город	Ростов-на-Дону

Проект «Разряд» разработан одним участником команды PixiPod. На слайде команды отдельно показаны участник и направления его работы. Сведения предоставлены капитаном; имя команды отличается от названия продукта.

Что осталось перед сдачей

1. Дополнить место работы/учёбы и телефон, если эти сведения обязательны в форме сдачи. Они не предоставлены; в материалах указан подтверждённый контакт Telegram.

2. При необходимости добавить личную мотивацию и фотографию. Биографические факты и прошлые достижения команды не выдумывались; технические сложности описаны по фактам реализации.

3. Перед отправкой повторно проверить доступность временного стенда и загрузить ссылки в личный кабинет капитана.

Репозиторий: https://github.com/ArtycoBW/-

Демонстрация: https://especially-eng-finally-walt.trycloudflare.com

Ссылка Cloudflare временная: компьютер и Docker должны работать; при перезапуске туннеля адрес может измениться. Резервная запись лежит в output/demo/Разряд-демонстрация.mp4. В PDF и презентации фактические результаты проверок отделены от задач промышленного пилота.

Сценарий защиты на 10 минут

Время	Действие
0:00-1:00	Проблема: самоописание в резюме не равно подтверждённой компетенции; ценность обратного найма
1:00-2:00	Команда и обязательные блоки шаблона
2:00-4:30	Профиль → тест → категория → потребность работодателя → приглашение с зарплатой
4:30-5:30	Принятие предложения; контакт виден этой компании, другой компании скрыт
5:30-6:30	Архитектура, транзакции, роли, согласия, отсутствие внешних платных API
6:30-8:00	Формула и модель; разбиение синтетики; test-retest и границы применимости
8:00-9:00	Вакансии, отклики, PDF, практика, мобильный интерфейс
9:00-10:00	API ФСП и OIDC, экспертная калибровка, пилот и дальнейшие шаги

Проверка перед отправкой

- Код клонируется по публичному URL; README соответствует текущему состоянию.
- Ссылки открываются в приватном окне браузера.
- Демодоступ работает и явно обозначен как демонстрационный.
- Презентация не содержит незаполненных сведений о команде.
- PDF скачивается и содержит архитектуру, алгоритмы, методику, результаты и запуск.
- Запись показывает реальный продукт и основной сценарий, а не только лендинг.
- Исходная переписка, персональные данные пользователей платформы, пароли окружения и локальные данные в репозитории отсутствуют. Контакт капитана опубликован в материалах защиты по его указанию.

Как проверить «Разряд»

Текущий стенд: https://especially-eng-finally-walt.trycloudflare.com - временный адрес Cloudflare. Постоянная точка входа в код и инструкции: https://github.com/ArtycoBW/-

Интерфейс работает на русском. Новый пользователь входит сразу после регистрации: подтверждение почты отключено. Cloudflare предоставляет HTTPS и маршрут к приложению, но не проверяет владение электронной почтой.

Подготовка

Откройте стенд в двух разных профилях браузера или в обычном и приватном окнах. Так сессии специалиста и компании не заменят друг друга. Начальные профили, компании, достижения и вакансии демонстрационные, с реалистичными описаниями. Это не реальные персональные данные и не действующие предложения о работе.

Аккаунт	Назначение	Пароль
candidate@demo.razryad.ru	Александр Волков, Python Middle: профиль и входящее предложение	RazryadDemo2026!
frontend@demo.razryad.ru	Анна Соколова, Frontend Middle: другой стек и достижения	RazryadDemo2026!
starter@demo.razryad.ru	Илья Новиков: заполненный профиль без подтверждённого грейда	RazryadDemo2026!
employer@demo.razryad.ru	Контур Лаб: потребности, вакансии, приглашения	RazryadDemo2026!
team@demo.razryad.ru	Север Технологии: независимая проверка доступа	RazryadDemo2026!

Демоаккаунты общие: действия другого посетителя могут изменить их состояние. Для чистого сценария зарегистрируйте отдельные аккаунты. Никогда не вводите в публичное демо чужие контакты, документы или рабочие пароли.

1. Лендинг и регистрация

1. Откройте главную при масштабе браузера 100%. На широком экране композиция компактнее; заголовок и основные кнопки видны без изменения масштаба.

2. Прокрутите до карточки приглашения: сообщение, зарплата и кнопки не пересекаются. В блоке приватности читаются состояния доступа, нет NaN. Подпись результата теста помещается внутри виджета.

3. Проверьте страницу входа на телефоне и компьютере. При настройке ОС «уменьшение движения» фон становится статичным.

4. Создайте специалиста с новой почтой и паролем от 10 символов. Дайте согласие. Ожидается немедленный переход в кабинет, без письма.

5. Выйдите и войдите с теми же данными. Неверный пароль выдаёт понятную ошибку. Кнопка с глазом показывает и скрывает пароль.

2. Профиль и тест

1. У нового специалиста заполните город, стек, опыт, зарплату и контакт. Включите публикацию и сохраните. Перезагрузите страницу: данные сохранены.

2. До прохождения теста компания не должна находить профиль в банке подтверждённых специалистов.

3. Выберите специализацию и грейд. Начните тест, ответьте на несколько вопросов, сохраните черновик и обновите страницу. Ответы и оставшееся время сохраняются.

4. Завершите тест. При 70 баллах и выше категория подтверждается; при неуспехе можно выбрать другую категорию по правилам интервалов. Повторная отправка не должна менять уже рассчитанный результат.

5. Скачайте PDF-профиль. Текст на русском, результаты и достижения соответствуют кабинету.

3. Подбор и приватность

1. Войдите компанией «Контур Лаб». Откройте «Найти специалистов». Создайте потребность: backend, middle, Python/FastAPI/PostgreSQL, удалённо, 180-260 тыс. рублей.

2. В подборке должны остаться специалисты выбранной категории. Откройте объяснение балла: совпавшие и недостающие навыки, тест, активность, вклад ФСП. Балл не называется вероятностью найма.

3. Откройте Александра Волкова: его личный контакт скрыт. Отправьте приглашение с зарплатой и контактом компании.

4. В окне специалиста проверьте условия и примите приглашение. Только теперь «Контур Лаб» видит контакт.

5. В третьем окне войдите «Север Технологии». Контакт этого специалиста должен оставаться закрытым, пока он отдельно не согласится этой компании. Если ранее уже принималось её стартовое предложение, используйте нового специалиста.

6. Отклоните другое предложение. Условия и история остаются доступны, новый доступ к контактам не появляется.

7. Отзовите разрешение в профиле специалиста. Обновите страницу компании: контакт снова скрыт.

4. Вакансии, отклики и практика

1. Создайте вакансию от компании. Проверьте в списке специалиста фильтры по направлению и грейду.

2. Откликнитесь с сопроводительным текстом и отдельным согласием на контакт. Повторный отклик на ту же вакансию не создаёт дубликат.

3. Компания читает отклик и меняет статус. Специалист видит обновление.

4. Создайте практическую задачу с критериями. Специалист отправляет решение. Компания ставит оценку и обратную связь. Она видна автору решения.

5. Архивируйте вакансию. Она исчезает из доступных для новых откликов; история сохраняется.

5. Негативные сценарии

- Зарплата «от» больше «до»: сервер отклоняет запись, форма показывает ошибку.
- Публикация без согласия: сервер отклоняет действие.
- Кандидат открывает URL раздела работодателя: нет доступа к функциям компании.
- Изменение чужого ID приглашения/попытки: отказ без выдачи чужих данных.
- Потеря соединения: сообщение об ошибке; после восстановления запрос можно повторить.
- Истекшая сессия: переход на вход; пароли и сессионные токены не появляются в URL.
- Почтовые маршруты без настройки: отключены; ссылки сброса пароля публичный API не выдаёт.

Автоматические проверки

```
venv/Scripts/python.exe -m pytest tests -q
venv/Scripts/python.exe -m ml.evaluate_robustness
cd frontend
npm run lint
npm run typecheck
npm run build
$env:E2E_DATABASE='postgres'
npm run test:e2e
```

E2E создаёт собственный профиль в БД стенда. Правильные ответы тест получает через доверенный доступ к локальной БД; публичный API их не раскрывает. Для проверки навыков живого пользователя эти подсказки не используются.

Когда включён Cloudflare, перед npm run test:e2e в каталоге frontend задайте $env:PLAYWRIGHT_BASE_URL=(Get-Content ../.local/public-url.txt -Raw).Trim(). Проверки пойдут через HTTPS. Для локального режима адрес по умолчанию - http://localhost:3000; он должен совпадать с PUBLIC_ORIGIN, а COOKIE_SECURE должен быть false. Одновременно смешивать локальный HTTP-вход и публичный HTTPS-вход с разными origin не следует. Скрипт записи демонстрации тоже поддерживает переменную PLAYWRIGHT_BASE_URL.

Готовность, модель и эксплуатация

Что можно утверждать

«Разряд» решает основной демонстрационный сценарий кейса: профиль специалиста, тест выбранного уровня, подтверждённая категория, подбор по потребности компании, приглашение с зарплатой и адресная передача контактов. Дополнительно работают вакансии, отклики, практика с оценкой работодателя, PDF и отзыв доступа к контактам.

Это работающий хакатонный прототип. Формулировка «всё сделано на максимум и готово для промышленной эксплуатации» пока не подтверждается. Проверки программы не заменяют проверку профессионального грейда, прав доступа к официальному реестру или пилот реального найма.

Область	Реализовано	Что остаётся для промышленного пилота
Бэкенд	FastAPI, роли, владельцы ресурсов, транзакции, уникальность, сессии, аудит согласий, проверка входных данных	Формальные миграции схемы, управление жизненным циклом аккаунтов, интеграционные SLA
Фронтенд	Next.js, русский интерфейс, два кабинета, адаптивность, обработка ошибок, клавиатура, reduced motion	Полный WCAG-аудит, реальные пользовательские исследования и проверка Safari/Firefox
Подбор	Фильтрация категории, нормализация стека, формула, экспортированная обученная модель, объяснение и fallback	Независимая экспертная разметка и измерение результатов найма
Тестирование навыков	Две специализации, три грейда, параметризованный банк, сохранение и таймаут, интервалы повторов	Экспертная калибровка сложности, расширение банка, эмпирическая психометрика и антифрод
История ФСП	Отдельно маркированный демореестр и сценарий профиля без ФСП	Официальный контракт API и OIDC/Keycloak; доступ не предоставлен
Хранилище	PostgreSQL, закрытый порт, постоянный volume, согласованный backup	Политика хранения/удаления, регулярное расписание backup, репликация по требуемому RPO/RTO
Инфраструктура	Контейнеры без root для приложения, healthchecks, автоматический рестарт, HTTPS-туннель	Постоянный сервер и домен, наблюдение с оповещениями, резервирование
Масштабирование	Пакетная загрузка связей, отсутствие N+1 в подборе	Ранжирование сейчас до пагинации; для большого банка нужен отдельный retrieval-этап, индекс навыков и нагрузочный профиль
Уведомления	Состояния приглашений и откликов доступны в кабинетах	Очередь доставки, outbox, повторные попытки и реальные каналы связи
Модерация	Контроль роли и владельца, безопасная выдача контактов	Проверка компаний, кабинет оператора, разбор споров и злоупотреблений

Распределённая система не добавлена ради названия: текущий стенд имеет один процесс API и одну PostgreSQL. Ограничитель авторизации работает в памяти одного процесса. При нескольких репликах нужен общий rate limiter, например Redis, а не увеличение числа процессов без изменения защиты. Пул соединений и запросы следует настраивать по измеренной нагрузке.

Итоговая модель

Артефакт ml/model.json содержит действительно обученные коэффициенты логистической регрессии, порядок признаков, seed и происхождение данных. Бэкенд загружает именно этот файл. Формула даёт 70%, модель 30% итогового балла. Если файл отсутствует или повреждён, подбор продолжает работать по формуле. Контакты, имя и защищённые характеристики не являются признаками модели.

Модель обучена на 5 120 синтетических парах; валидация использует 1 280 пар, тест 1 920. Группы потребностей и кандидатов разделены. Метрики, SHA-256 и настройки зафиксированы в ml/metrics.json. JSON экспортирован без исполняемого pickle. Тест проверяет совпадение SHA-256 и монотонность оценки при улучшении навыков.

Дополнительная проверка ml/evaluate_robustness.py: пять новых seed, 400 подборок и 12 800 пар, случайное ранжирование как контроль, отключение истории ФСП, парный bootstrap на уровне подборок. Средняя разница NDCG@5 «гибрид минус формула» составляет 0,01159; 95% bootstrap-интервал [0,00932; 0,01400]. Результат сохранён в ml/robustness.json.

Почему этого недостаточно для «финальной модели реального найма»: все выборки происходят из одной программно заданной модели предпочтений, близкой по признакам к самой формуле. Высокий NDCG ожидаем; он не означает 99% точности найма. Новые seed проверяют устойчивость, а не внешнюю валидность. Случайные метки не являются отзывами работодателей. Не установлены реальные fairness, калибровка вероятностей или прирост трудоустройства.

Практический следующий шаг: независимые оценки экспертов по парам «потребность + профиль», временное разбиение без пересечений участников, сравнение с формулой и случайным контролем, A/B-пилот с явным согласием и мониторингом обратной связи. До этого модель помогает сравнивать профили, но не принимает автоматические решения об отказе.

Публичный демонстрационный стенд

```
docker compose up --build -d
docker compose exec api python -m backend.demo_scenarios
powershell -ExecutionPolicy Bypass -File scripts/start-tunnel.ps1
```

Скрипт получает временный HTTPS-адрес, записывает его в .local/public-url.txt, выставляет точный PUBLIC_ORIGIN, защищённую cookie и доверие заголовку IP от Cloudflare. База и API напрямую наружу не публикуются. Туннель открывает только web-сервис; Mailpit остаётся на localhost. Переменные и логи не включаются в Git.

Проверка текущего внешнего HTTPS-стенда: /api/v1/ready отвечает успешно; вход во все пять подготовленных аккаунтов и регистрация без письма работают. Cookie сессии имеет Secure и HttpOnly. Запрос изменения состояния с посторонним Origin отклонён кодом 403. Ошибок JavaScript в этом браузерном сценарии не было. Проверки выполнены на Chromium; это не полное межбраузерное или нагрузочное испытание.

Полный набор из семи браузерных сценариев повторён через Cloudflare: семь успешных, 51,1 секунды, без пропусков и нестабильных повторов. Локальный прогон того же набора занял 25,8 секунды.

Quick Tunnel предназначен для демонстрации. При перезапуске туннеля адрес может измениться: повторно запустите скрипт. Пока используется этот способ, компьютер и Docker должны оставаться включёнными. Для постоянной ссылки нужен named tunnel в Cloudflare и собственный домен. Документация Cloudflare.

На публичной демонстрации DEMO_MODE=true намеренно даёт доступ к общим учебным аккаунтам. Для реального пилота отключите демонстрационные методы и загрузку фикстур. Регистрация без проверки почты не доказывает владение адресом и не заменяется Cloudflare Tunnel; это отдельная продуктовая настройка по текущему решению команды.

EMAIL_VERIFICATION_REQUIRED=false, PASSWORD_RECOVERY_ENABLED=false, EXPOSE_DEMO_MAIL=false: ни подтверждение, ни восстановление через недоставляемое письмо не предлагаются. При подключении настоящего SMTP функции можно включить. Нельзя открывать публично EXPOSE_DEMO_MAIL=true: этот параметр предназначен исключительно для изолированных тестов.

Резервные копии и восстановление

```
.venv/Scripts/python.exe scripts/backup.py
```

Согласованный pg_dump -Fc сохраняется в .local/backups. Скрипт проверяет каталог архива через pg_restore --list. Проверка полного восстановления выполняется scripts/verify-backup.py: создаётся отдельная временная БД, туда восстанавливается архив, проверяются ключевые таблицы, после проверки удаляется только эта временная БД. Рабочая БД не заменяется.

Для восстановления рабочей БД сначала остановите записи, сделайте дополнительный backup и проверьте архив в отдельной БД. Замена работающей БД требует отдельного решения оператора. docker compose down сохраняет volume; down -v удаляет данные и не является обычным перезапуском.

Зависимости и границы проверок

Runtime-проверка npm audit --omit=dev не выявила известных уязвимостей на момент сборки. Полный audit показывает пять high-записей в цепочке инструментов ESLint из-за braces@3.0.3; совместимое исправление на момент проверки отсутствует. Автоматически откатывать Next.js на старшую уязвимую/несовместимую ветку ради зелёного отчёта нельзя. Эта dev-цепочка не входит в standalone runtime.

Успешные тесты подтверждают конкретные сценарии и ограничения. Они не означают отсутствие всех ошибок, аудит всей безопасности, соответствие любому объёму нагрузки или готовность работать с реальными персональными данными без дополнительных организационных мер.